

No. 01. Explain CIA Triad.

The **CIA Triad** is a foundational model in cybersecurity that represents the three core principles essential for ensuring information security:

Confidentiality

Confidentiality focuses on restricting access to sensitive data. It ensures that information is shared only with authorized personnel. Confidentiality means keeping information private and ensuring only authorized people can access it. It protects sensitive data from being seen, shared, or stolen by unauthorized individuals.

- Data classification (e.g., public, confidential, secret).
 - Policies for data sharing and access rights.
 - Protecting data in transit and at rest through encryption.
-
- **Common Threats:**
 - Data breaches.
 - Insider threats.
 - Unsecured communication channels (e.g., unencrypted emails).
 - **Examples:**
 - Using VPNs for secure communication.
 - Multi-factor authentication (MFA) to verify user identity.

Integrity

Integrity ensures that data remains unaltered and trustworthy throughout its lifecycle. Integrity means ensuring that information stays accurate and unchanged, except by authorized people or processes. It guarantees that the data is trustworthy and not tampered with, whether accidentally or intentionally.

- Preventing unauthorized modifications to data.
 - Detecting changes when they occur and ensuring proper recovery mechanisms.
 - Ensuring system logs remain untampered for accurate auditing.
-
- **Common Threats:**
 - Malware or ransomware altering files.
 - Unauthorized users modifying databases.
 - Man-in-the-middle (MITM) attacks injecting false data.

- **Examples:**

- Hashing algorithms (e.g., SHA-256) to verify data authenticity.
- Version control systems to track changes.
- Integrity monitoring tools to detect unauthorized changes.

Availability

Availability guarantees that information and systems are accessible to authorized users whenever needed. Availability means ensuring that information and systems are accessible to authorized users whenever they need them. It prevents disruptions caused by hardware failures, cyberattacks, or other issues.

- Minimizing downtime and ensuring business continuity.
- Managing system loads to prevent resource exhaustion.
- Addressing vulnerabilities to mitigate denial-of-service (DoS) attacks.

- **Common Threats:**

- Distributed Denial of Service (DDoS) attacks.
- Hardware or software failures.
- Natural disasters disrupting systems.

- **Examples:**

- Load balancers to distribute traffic across servers.
- Backups stored in geographically diverse locations.
- Use of Uninterruptible Power Supplies (UPS) to handle power outages.

No. 02. explain various types of attacks in network.

Network attacks are malicious activities aimed at disrupting, accessing, altering, or stealing information from networks. The various types of network attacks are:

1. Denial of Service (DoS) and Distributed Denial of Service (DDoS) Attacks

- **DoS:** An attacker overwhelms a network or server with excessive requests, causing it to become slow or unavailable to legitimate users.
- **DDoS:** Similar to DoS but launched from multiple systems, often using a botnet of compromised devices, making it more difficult to stop.
- Attackers can exploit vulnerabilities in network devices or software to amplify the impact, such as using UDP amplification attacks to generate massive traffic.

2. Man-in-the-Middle (MITM) Attacks

- An attacker secretly intercepts and potentially alters communication between two parties without their knowledge.
- Often executed over insecure networks (e.g., public Wi-Fi) to eavesdrop or steal sensitive information.
- Attackers can use fake security certificates (SSL stripping) to trick users into believing they are connecting to a secure site while actually communicating through the attacker.

3. Phishing and Spear Phishing

- Phishing: Attackers send fraudulent emails or messages that appear legitimate to trick users into sharing sensitive information, like passwords.
- Spear Phishing: More targeted, where attackers customize messages to a specific individual or organization, often using personal information.
- Attackers may embed malicious links or attachments designed to download malware or lead users to credential-stealing websites.

4. Ransomware

- A type of malware that encrypts a victim's data and demands payment to restore access.
- Often spreads through malicious attachments or links in phishing emails.
- Some advanced ransomware variants not only encrypt files but also exfiltrate sensitive data, threatening to leak it unless the ransom is paid.

5. SQL Injection

- Attackers exploit vulnerabilities in a web application's database query processing by injecting malicious SQL code.
- This can lead to unauthorized data access, deletion, or even control over the database.
- Attackers may use SQL injection to bypass authentication, such as logging in without valid credentials by manipulating the database query.

6. Cross-Site Scripting (XSS)

- An attacker injects malicious scripts into webpages that are then executed in a user's browser.
 - Can lead to stolen cookies, session hijacking, or redirection to malicious websites.
 - Stored XSS allows attackers to permanently inject malicious scripts into a web application, affecting every user who views the compromised page.
-

7. Eavesdropping/Sniffing Attacks

- Attackers capture and monitor network traffic, often on unencrypted networks, to gather sensitive information.
 - Tools like packet sniffers can be used to listen to data transmissions.
 - Attackers can exploit weak or outdated encryption protocols (e.g., WEP on Wi-Fi networks) to intercept sensitive data.
-

8. Brute Force Attacks

- Attackers repeatedly try different combinations of passwords or keys until they find the correct one.
 - Can be mitigated using account lockout policies and multi-factor authentication.
 - Attackers may use automated tools or bots to carry out attacks at scale, testing thousands of password combinations in minutes.
-

9. Malware Attacks

- Malware includes viruses, worms, trojans, spyware, and adware that infect networks and devices.
 - It can disrupt operations, steal data, or provide attackers with remote control over systems.
 - Advanced malware may use polymorphic techniques to continuously change its code, making it harder for antivirus software to detect.
-

10. ARP Spoofing

- An attacker sends fake Address Resolution Protocol (ARP) messages to link their MAC address with an IP address of another device, redirecting traffic.
- Often a precursor to a MITM attack or DoS.

- Attackers may combine ARP spoofing with packet sniffing to steal session cookies, enabling them to hijack user accounts or impersonate users.
-

11. DNS Spoofing/Poisoning

- Attackers corrupt DNS entries to redirect traffic from a legitimate website to a fraudulent or malicious site.
 - Can lead to phishing or malware delivery.
 - Attackers can poison DNS cache entries to redirect multiple users or domains to malicious sites, spreading attacks at scale.
-

12. Insider Attacks

- Threats posed by individuals within the organization who have inside information or access.
 - Often involve misuse of access rights, leading to data theft or system sabotage.
 - Insiders may intentionally or unintentionally plant malware on systems by bringing in compromised external devices, such as USB drives.
-

13. Password Attacks

- Includes dictionary attacks, brute force, and keylogger attacks to guess or intercept passwords.
- Weak passwords and lack of MFA increase vulnerability.
- Credential stuffing attacks use stolen username-password pairs from previous breaches to gain access to accounts where users reuse credentials.